HCLS AI Agent Suite

Governed Agentic AI for Life Sciences — Built on AWS

Eight reference agents on one 21 CFR Part 11 / GxP-defensible platform — the agent isn't the product, the governance is.

Executive Overview · Built on AWS · June 2026

EVERYONE'S MOVING. FEW ARE GOVERNED.

In a workflow where a hallucinated number is a data-integrity defect, governance is the gap this platform closes.

$60–110B

/yr potential gen-AI value for pharma & medical products

[industry-research — McKinsey 2023]

~5%

of commercial life-sci firms have turned gen AI into real value

[industry-research — McKinsey 2024]

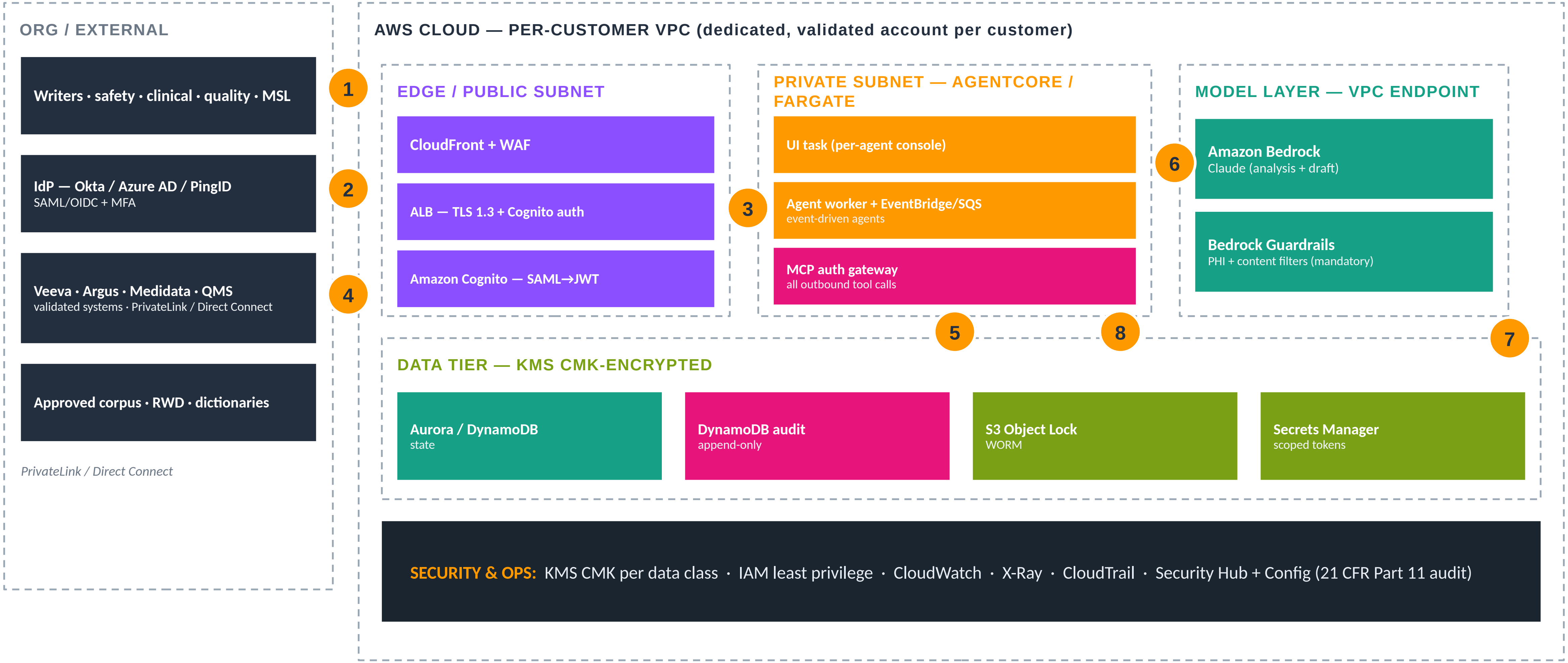
Jan 2025

FDA draft guidance on AI in regulatory decision-making (7-step credibility)

[gov/peer-reviewed — FDA]

The takeaway: this platform is the governance layer that lets a sponsor adopt AI as fast as the market — and defend it to an FDA/EMA inspector.

Shared AWS Architecture & Traffic Flow



1 sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT — no credentials in AWS) 3 authenticated session 4 systems-of-record read over private connectivity 5 queue/scale for event-driven agents 6 model calls stay in-VPC via Bedrock + Guardrails endpoint (PHI masked first) 7 every action persisted to append-only audit (21 CFR Part 11) 8 tools reachable only through the governed MCP gateway

The 8-Agent Portfolio — Land-first (document- & case-centric)

01 Regulatory Writing & Intelligence

draft and assemble submission content from grounded evidence — a qualified human signs off

Headline: $2.6B — average capitalized cost per approved drug — the value behind every submission

Cost of doing nothing: ~$60M / month

02 Pharmacovigilance — ICSR Case Intake

triage, de-duplicate, MedDRA-code, and draft E2B narratives — a safety physician validates the case

Headline: ~28M — cumulative FAERS reports by end-2023; quarterly volume ~3× since 2007

Cost of doing nothing: ~$2.0M / yr

03 Clinical Trial Ops & TMF

surface TMF gaps and EDC query backlog continuously — a CRA approves every disposition

Headline: ~$800K / day — lost/delayed sales per day of trial delay (+ ~$40K/day direct cost)

Cost of doing nothing: ~$25.7M / slip

08 Medical Affairs / MSL Copilot

draft on-label, evidence-grounded HCP responses — MLR review approves before anything ships

Headline: weeks→months — MLR review is the single biggest content-release bottleneck

Cost of doing nothing: Billions in FCA risk

The 8-Agent Portfolio — Higher-governance (sequence after)

04 Site Selection & Patient Matching

rank sites on real performance and size cohorts on RWD — humans select sites and confirm eligibility

Headline: ~80% — of trials miss their original enrollment timeline

Cost of doing nothing: ~$24M / launch

05 Quality / CAPA & Complaints

draft root-cause and CAPA, score complaints — a quality owner approves classification and closure

Headline: #1 cited — CAPA (21 CFR 820.100) is consistently the most-cited FDA device 483 clause

Cost of doing nothing: $10M–$100M / recall

06 Clinical Protocol Design & Feasibility

draft protocol sections grounded in guidance and RWD — clinical leads own the design

Headline: ~57% — of protocols incur ≥1 substantial amendment; ~45% avoidable

Cost of doing nothing: ~$535K / amendment

07 Real-World Evidence / HEOR

build cohorts and translate code so analysts analyze — an epidemiologist approves the study

Headline: ~45% — of analyst time goes to data prep, not analysis (measured)

Cost of doing nothing: ~$1.3M / yr / team

The Governance & Compliance Spine

Every agent inherits the same controls — mapped to the regulations life-sciences buyers are inspected against.

Regulation / framework	Mapped control on the platform
21 CFR Part 11 (records / e-sig)	Append-only audit; bound reviewer identity on every gate; system validation posture; KMS CMK encryption
GxP / ALCOA+ (data integrity)	Grounding verification; every figure traceable to source; prompt version pinning; tamper-evident lineage
GVP / ICH E2B(R3) (safety)	PHI masked before model calls; safety-physician gate on causality & reportability (Agent 02)
ICH E6(R3) GCP (trials)	Continuous TMF completeness; CRA gate on dispositions; inspection-ready audit (Agent 03)
HIPAA / de-identification	Safe Harbor / Expert Determination enforced at the gateway for any RWD use (Agents 04/07)
FDA AI guidance (Jan 2025) + NIST AI RMF	Risk-based credibility framing; Guardrails, explainable grounded output, framework-enforced HITL

The Maturity Ladder

Climb at the sponsor's own pace — each rung reuses the same governed control plane.

1 · Documented

Architecture, workflow, and compliance design written and reviewed. Useful for discovery and architecture review.

2 · Demonstrated

Runs end-to-end in demo mode (no API key, deterministic fixtures). Internal demos and customer workshops.

3 · Deployable

CloudFormation + container contracts + CI pass; customer AWS account + Bedrock. Suitable for a pilot.

4 · Production-ready

CSV/CSA complete, IdP integrated, connectors live, pen-test passed. The engagement milestone.

The suite sits at Demonstrated + Deployable-by-design — 452 tests pass with no API key; production-readiness is the engagement.

Deployment — One Platform, Per-Customer Isolation

1 Foundation

Per-customer VPC + dedicated, validated AWS account; KMS CMK per data class; network to systems-of-record (PrivateLink / Direct Connect).

2 Identity

Cognito SAML→JWT federation with role scoping (writer / safety / CRA / quality / MSL / reviewer). No credentials stored in AWS.

3 Edge

CloudFront + WAF; ALB TLS 1.3; Cognito auth at the edge.

4 Agent + tools

Deploy the AgentCore/Fargate agent; grant tools via the deny-by-default MCP gateway with short-lived scoped tokens.

5 Connectors + data

Wire Veeva / Argus / Medidata / QMS connectors and Secrets Manager; index approved corpus; add per-agent blocks (EventBridge, Step Functions HITL).

6 Governance + go-live

Bedrock Guardrails (mandatory); S3 Object Lock + DynamoDB append-only audit; CloudTrail / Security Hub / Config; smoke + HITL test.

Reference: docs/DEPLOY-QUICKSTART.md · docs/DEPLOYMENT-HANDBOOK.md · aws-native-reference/<agent>/DEPLOY.md

Land-and-Expand

Prove the governed control plane with document- and case-centric agents, then expand to higher-governance workloads on the same foundation.

LAND

01 Regulatory Writing · 02 Pharmacovigilance (live path) · 03 Trial Ops/TMF · 08 Medical Affairs

Document- and case-centric, measurable. Proves identity, gateway, PHI masking, audit, and Guardrails in production.

EXPAND

05 Quality/CAPA · 06 Protocol Design

Add reportability and design-ownership gates on the now-proven control plane.

SCALE

04 Site/Patient Matching · 07 RWE/HEOR

Highest-governance: de-identified RWD, enforced at the gateway, with auditable lineage.

The Suite-Level Cost of Inaction

Per-agent cost of doing nothing, at a reference sponsor — substitute your own volumes.

Agent	Cost of inaction
01 Reg Writing	~$60M / month
02 Pharmacovigilance	~$2.0M / yr
03 Trial Ops / TMF	~$25.7M / slip
04 Site / Patient	~$24M / launch
05 Quality / CAPA	$10M–$100M / recall
06 Protocol Design	~$535K / amendment
07 RWE / HEOR	~$1.3M / yr / team
08 Medical Affairs	Billions in FCA risk

Several are modeled at a reference baseline (shown as such); 01/03/05/06 lean on direct published figures. None are guaranteed — they substitute the customer's actuals.

The Takeaway

The agent isn't the product. The governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Eight reference agents · one control plane · land-first with 01 / 02 / 03 / 08 · expand at your own pace.

Regulatory Writing & Intelligence

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 01 of 8 · draft and assemble submission content from grounded evidence — a qualified human signs off

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM SEARCHING TO SUBMITTING

Regulatory Writing & Intelligence

A governed medical-writing copilot that retrieves approved evidence, drafts and assembles CTD/eCTD sections with every figure traceable to source — while a qualified regulatory writer reviews and signs off on what is submitted.

$2.6B

average capitalized cost per approved drug — the value behind every submission

[gov/peer-reviewed — DiMasi/Tufts]

~$60M / mo

NPV lost per month of submission delay for a $1B-peak asset

[industry-research — McKinsey 2025]

~55%

first-draft CSR hours cut (180→80) with 50% fewer errors (Merck)

[vendor — Merck-reported]

The Issue & The Cost of Doing Nothing

THE ISSUE

- Medical writers spend disproportionate time retrieving and reconciling evidence rather than reasoning.
- A hallucinated number in a submission is a data-integrity defect — FDA's own gen-AI tool was reported to fabricate studies.
- Only ~13% of top pharma automate table/listing/figure assembly at scale; the rest is manual.
- Every regulated artifact carries 21 CFR Part 11 e-signature and ALCOA+ obligations before the first line of agent code.

THE COST OF DOING NOTHING

~$60M / month

Industry: ~$60M NPV lost per month of submission delay for a $1B-peak asset (~$180M for a 12-week slip). The FY2026 PDUFA filing fee alone is $4.68M.

- Data-integrity findings and refuse-to-file risk from inconsistent or unsourced figures.
- Reviewer time lost reconciling drafts assembled by hand across documents.

[industry-research — McKinsey 2025; FDA PDUFA FY2026]

The design line: the agent retrieves, drafts, and checks consistency; a qualified regulatory/medical writer reviews and signs off — nothing is submitted unedited.

How We Solve It — A Governed Pipeline

Retrieve approved evidence through a scoped gateway, draft and assemble grounded sections, verify every figure — then stop at a human gate before anything is filed.

1
Retrieve evidence
RIM/DMS + guidance via gateway-scoped connectors

→

2
Draft & assemble
CTD/eCTD sections grounded in source

→

3
Consistency check
every figure traceable; grounding fails fast

→

4
HUMAN GATE
qualified writer reviews & signs off

→

5
Append-only audit
lineage + e-signature to immutable store

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

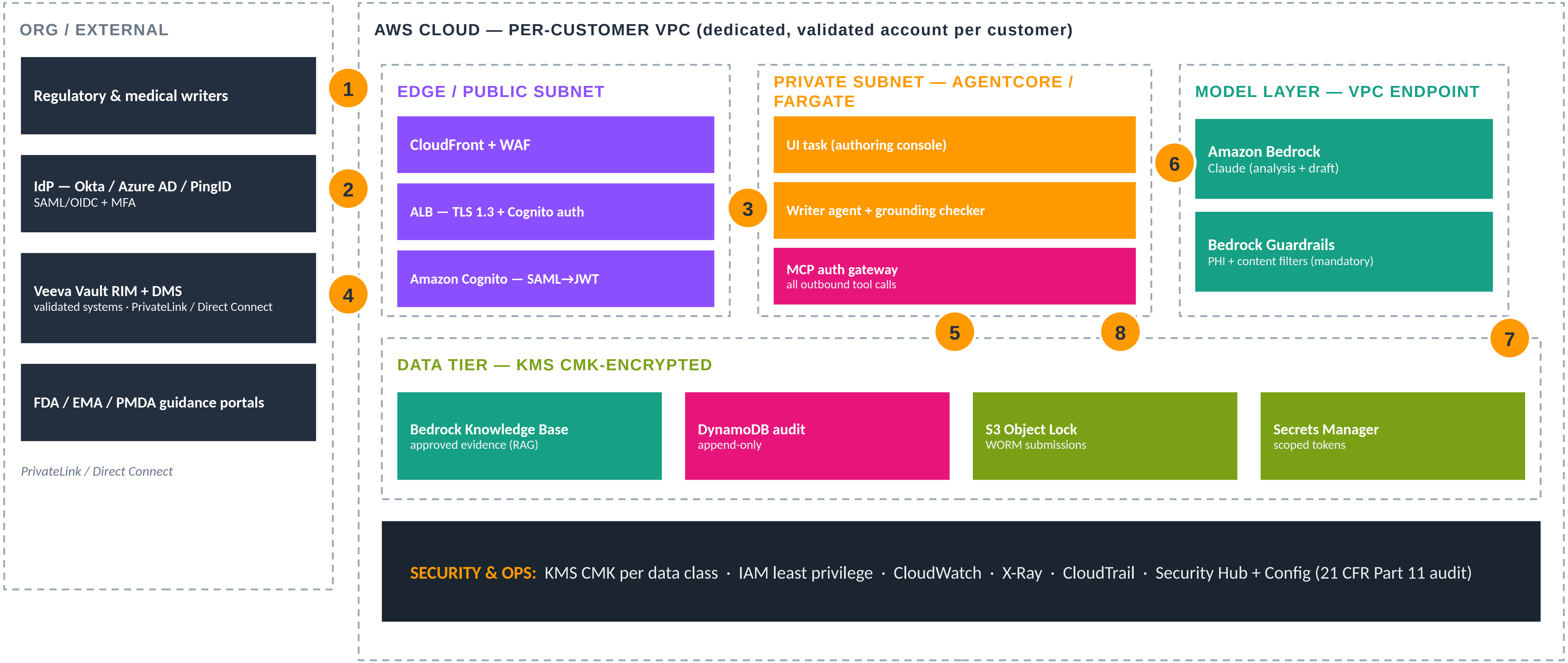
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides what gets submitted

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 writer sign-in   2 SAML federation (MFA at IdP; Cognito issues JWT — no credentials in AWS)   3 authenticated session to authoring console   4 RIM/DMS + guidance read over private connectivity   5 demand scales the agent workers   6 model calls stay in-VPC via Bedrock + Guardrails endpoint   7 every draft, source, and e-signature persisted to append-only audit   8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

~55%

first-draft CSR hours cut, 50% fewer errors (Merck)

[vendor — Merck]

~40%

CSR cycle-time reduction in early gen-AI pilots

[industry-research — McKinsey]

$4.68M

FY2026 PDUFA filing fee at stake per submission

[gov/peer-reviewed — FDA]

100%

of figures traceable to source by design (grounding gate)

[design property]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK per data class + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation with role scoping (writer / reviewer / QP).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect Veeva Vault RIM/DMS; index approved guidance into a Knowledge Base.
1. Enable S3 Object Lock + append-only audit; run smoke + HITL sign-off test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway + native/container agent; point connectors at Veeva Vault; index approved guidance.*

aws-native-reference/01-regulatory-writing/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Pharmacovigilance — ICSR Case Intake

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 02 of 8 · triage, de-duplicate, MedDRA-code, and draft E2B narratives — a safety physician validates the case

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM CASE BACKLOG TO SAME-DAY TRIAGE

Pharmacovigilance — ICSR Case Intake

A governed ICSR copilot that triages intake, detects duplicates, proposes MedDRA coding, and drafts the E2B(R3) narrative — while a safety physician validates causality and the reportable case before it leaves the building.

~28M

cumulative FAERS reports by end-2023; quarterly volume ~3× since 2007

[gov/peer-reviewed — FDA FAERS]

40–85%

of PV budgets consumed by case intake & processing

[sector-press/estimate]

40–70%

manual data-entry time cut in a Pfizer AI/RPA pilot

[gov/peer-reviewed — Schmider 2019]

The Issue & The Cost of Doing Nothing

THE ISSUE

- Adverse-event volumes scale with portfolio breadth; intake is high-volume and time-critical.
- Triage, duplicate detection, MedDRA coding, and E2B narrative drafting are repetitive and regulated.
- Case processing consumes up to two-thirds of internal PV resources; median ~69 min per report.
- ICSR volumes are growing ~8–15%/year — the backlog compounds without automation.

THE COST OF DOING NOTHING

~$2.0M / yr

Modeled: 100,000 cases/yr × ~$20 outsourced intake/case = ~$2.0M/yr before internal labor. Intake/processing is 40–85% of PV budget; ~8–15% annual volume growth.

- Late or missed expedited reporting — regulatory and patient-safety exposure.
- Coding inconsistency that undermines signal detection across the portfolio.

[modeled + sector-press/estimate]

The design line: the agent triages, de-duplicates, codes, and drafts; a qualified safety physician validates causality and the reportable case before submission.

How We Solve It — A Governed Pipeline

Ingest case data through a scoped gateway, propose triage / dedupe / MedDRA coding and draft the narrative — then stop at a safety-physician gate before reporting.

1
Ingest & mask
case sources via gateway; PHI masked first

→

2
Triage & dedupe
seriousness, expectedness, duplicate detection

→

3
Code & draft E2B
MedDRA coding + E2B(R3) narrative draft

→

4
HUMAN GATE
safety physician validates causality & case

→

5
Append-only audit
every decision logged to immutable store

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

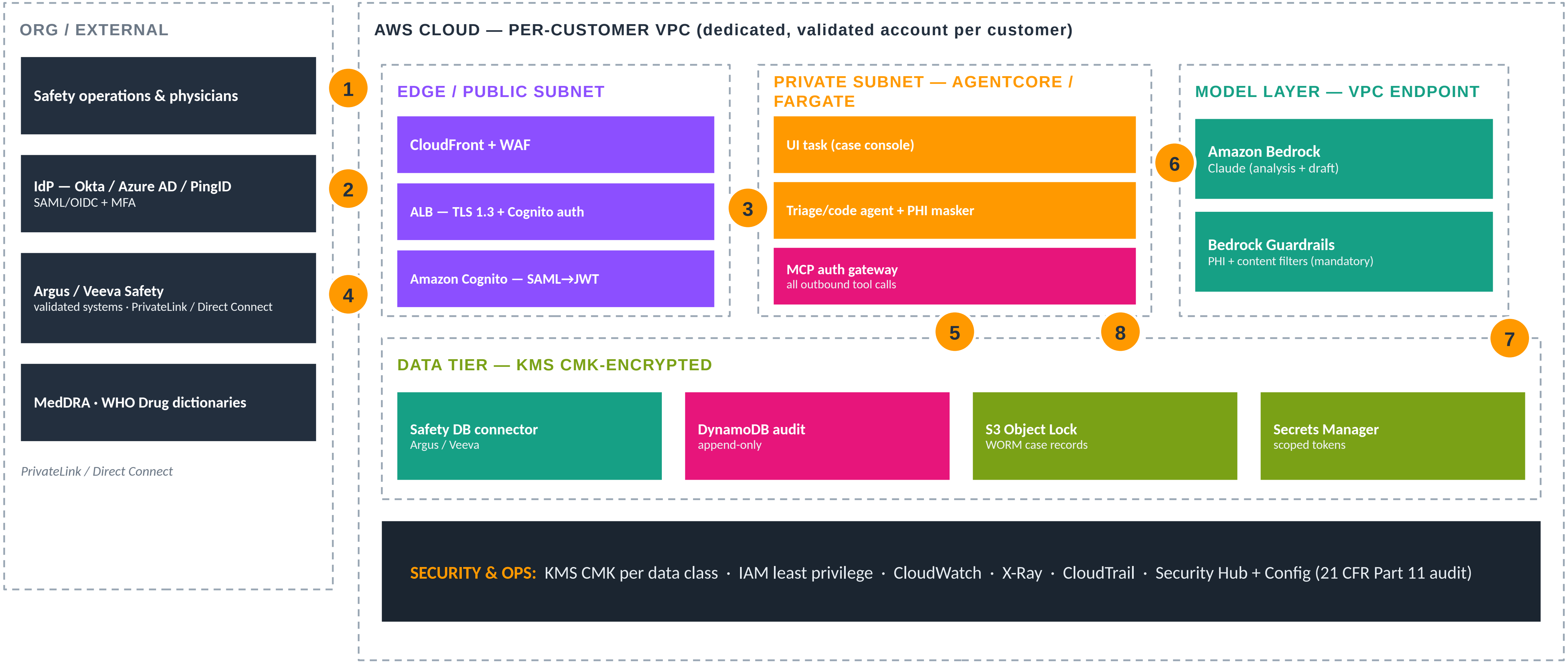
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides the reportable case

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 safety-ops sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to case console 4 safety DB + dictionary reads over private connectivity 5 case volume scales the agent workers 6 model calls stay in-VPC via Bedrock + Guardrails (PHI masked first) 7 every triage/coding/causality decision persisted to append-only audit 8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

40–70%

manual data-entry time cut (Pfizer pilot)

[gov/peer-reviewed — Schmider]

10–30%

PV cost savings with GenAI/automation deployed

[industry-research]

up to 2/3

of internal PV resources today go to case processing

[gov/peer-reviewed]

~69 min

median processing per report today — the target

[gov/peer-reviewed]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (safety-ops / physician roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect Argus/Veeva Safety + MedDRA/WHO Drug; enable PHI masker.
1. Enable S3 Object Lock + append-only audit; run the live end-to-end demo path.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway; Agent 02 ships a live Bedrock + real-connector reference path you can run end-to-end.*

aws-native-reference/02-pharmacovigilance/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Clinical Trial Ops & TMF

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 03 of 8 · surface TMF gaps and EDC query backlog continuously — a CRA approves every disposition

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM LATE SURPRISES TO CONTINUOUS READINESS

Clinical Trial Ops & TMF

A governed trial-ops copilot that monitors TMF completeness and EDC query backlog continuously and drafts the work — while a CRA or TMF owner approves every filing, query, and closure, keeping the trial inspection-ready by design.

~$800K / day

lost/delayed sales per day of trial delay (+ ~$40K/day direct cost)

[gov/peer-reviewed — Tufts 2024]

57%

of TMF owners still rely on paper / simple e-file systems

[industry-research — Veeva]

$19.0M

median pivotal-trial cost (IQR $12.2M–$33.1M)

[gov/peer-reviewed — JAMA IM]

The Issue & The Cost of Doing Nothing

THE ISSUE

- TMF gaps surface late — often after database lock, when they are most expensive to fix.
- EDC query backlogs slow enrollment and data cleaning; completeness is continuous, not periodic.
- “Failure to maintain adequate/accurate case histories” is among the most common FDA BIMO 483 findings.
- Advanced-eTMF users report inspection readiness of 56% vs. 25% — tooling gap is measurable.

THE COST OF DOING NOTHING

~$25.7M / slip

Modeled: a 30-day database-lock / TMF slip on one Phase III ≈ 30 × ($800K lost sales + $55,716 direct/day) ≈ ~$25.7M. Tufts 2024 supersedes the old “$4–8M/day” figure.

- Inspection findings and refuse-to-file risk from an incomplete TMF.
- Enrollment and lock delays compounding the per-day cost of delay.

[modeled — Tufts 2024 day-of-delay × Phase III direct cost]

The design line: the agent detects gaps and drafts queries; a CRA or TMF owner approves every filing, query, and closure — the disposition is human-owned.

How We Solve It — A Governed Pipeline

Continuously read eTMF/EDC/CTMS through a scoped gateway, detect gaps and draft queries — then route every disposition to a human gate.

1
Continuous read
eTMF / EDC / CTMS via gateway connectors

→

2
Detect gaps
completeness model vs. TMF reference model

→

3
Draft queries/actions
propose filings, queries, follow-ups

→

4
HUMAN GATE
CRA / TMF owner approves disposition

→

5
Append-only audit
every action logged to immutable store

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

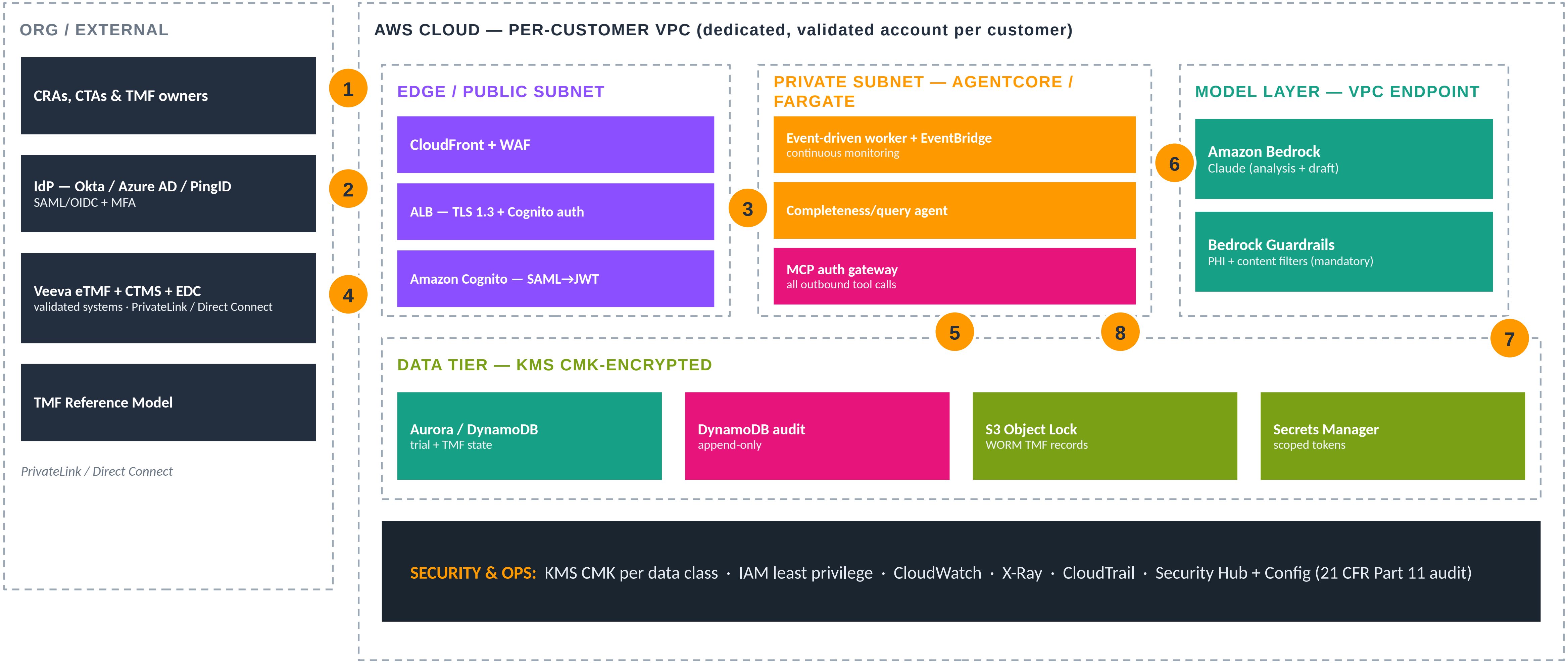
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides the TMF/query disposition

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 user sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to trial-ops console 4 eTMF/EDC/CTMS reads over private connectivity 5 EventBridge schedules continuous completeness checks 6 model calls stay in-VPC via Bedrock + Guardrails 7 every gap, query, and disposition persisted to append-only audit 8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

~$800K/day

delay cost the agent works to compress

[gov/peer-reviewed — Tufts]

56% vs 25%

inspection readiness, advanced-eTMF vs. manual

[industry-research — Veeva]

1M+ docs

auto-classified by a TMF bot, “tens of thousands of hours”

[vendor — Veeva]

continuous

completeness vs. periodic spot-checks today

[design property]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (CRA / CTA / TMF-owner roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect Veeva eTMF + CTMS + EDC; load the TMF Reference Model.
1. Wire EventBridge for continuous checks; enable audit; run smoke + HITL test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway + event-driven worker; point connectors at eTMF/EDC/CTMS.*

aws-native-reference/03-clinical-trial-ops/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Site Selection & Patient Matching

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 04 of 8 · rank sites on real performance and size cohorts on RWD — humans select sites and confirm eligibility

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM SITE GUESSWORK TO EVIDENCE

Site Selection & Patient Matching

A governed feasibility copilot that ranks sites on historical performance and sizes cohorts against real-world data — while humans select the sites and clinicians confirm every patient's eligibility, with diversity surfaced as a first-class metric.

~80%

of trials miss their original enrollment timeline

[sector-press/estimate — flag on slide]

~20% / ~30%

of sites enroll zero / under-enroll patients

[sector-press/estimate]

~36%

average screen-failure rate (70–85% in CNS/rare disease)

[sector-press/estimate]

The Issue & The Cost of Doing Nothing

THE ISSUE

- Feasibility still leans on site-opinion surveys rather than historical performance data.
- Real-world cohort sizing is rarely integrated at scale, so enrollment assumptions are optimistic.
- ~1 in 5 sites enroll no one and ~30% under-enroll — wasted activation cost and lost time.
- FDA Diversity Action Plan expectations make representativeness a design requirement, not an afterthought.

THE COST OF DOING NOTHING

~$24M / launch

Modeled: compressing enrollment by 30 days ≈ 30 × $800K/day lost sales ≈ ~$24M recovered per launch. Cost per patient recruited commonly $1,500–$10,000; recruitment is 20–30% of trial budget.

- Site activation spend on non-enrolling sites.
- Diversity-plan and ICH E17 gaps that jeopardize acceptability of the evidence.

[modeled — Tufts 2024 day-of-delay; recruitment benchmarks]

The design line: the agent ranks sites and sizes cohorts; humans select the sites and a clinician confirms each patient's eligibility — no autonomous enrollment.

How We Solve It — A Governed Pipeline

Read historical site performance and de-identified RWD through a scoped gateway, rank and size — then route selection and eligibility to humans.

1
Read performance + RWD
CTMS history + de-identified RWD via gateway

→

2
Rank & size cohorts
performance model + feasibility + diversity

→

3
Draft feasibility pack
ranked sites, cohort sizing, diversity view

→

4
HUMAN GATE
humans select sites; clinician confirms eligibility

→

5
Append-only audit
rationale + data lineage logged

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

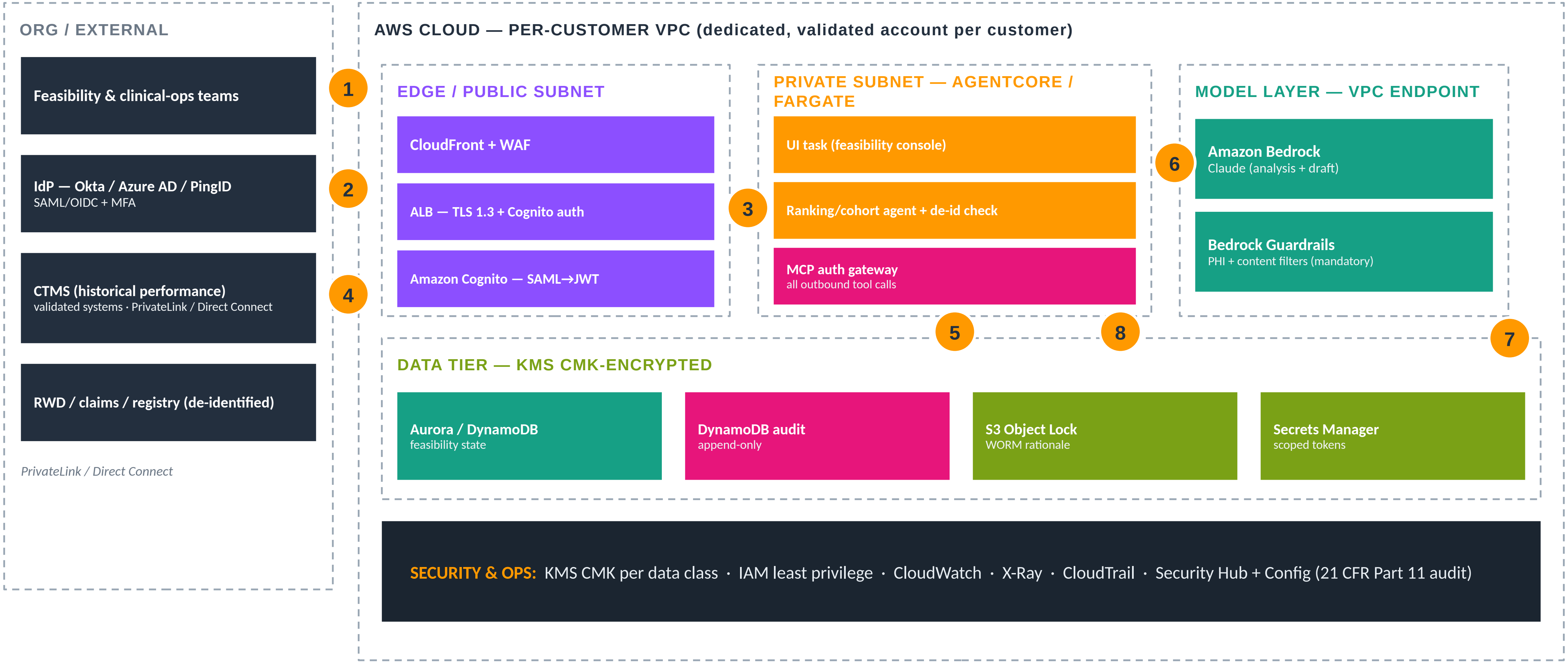
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides site selection & patient eligibility

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 user sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to feasibility console 4 CTMS + de-identified RWD reads over private connectivity 5 demand scales the agent workers 6 model calls stay in-VPC via Bedrock + Guardrails 7 ranking rationale + data lineage persisted to append-only audit 8 connectors reachable only through the governed MCP gateway (de-identification enforced)

Proof, Payback & How to Deploy

MEASURED OUTCOMES

~$24M

modeled recovery per launch from a 30-day pull-in

[modeled]

evidence

historical performance vs. opinion surveys

[design property]

diversity

representativeness surfaced as a first-class metric

[FDA Diversity Action Plan posture]

de-identified

RWD via Safe Harbor / Expert Determination

[HIPAA]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (feasibility / clinician roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect CTMS history + de-identified RWD; enforce de-identification at the gateway.
1. Enable S3 Object Lock + append-only audit; run smoke + HITL test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway; point connectors at CTMS history and a de-identified RWD source.*

aws-native-reference/04-site-patient-matching/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Quality / CAPA & Complaints

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 05 of 8 · draft root-cause and CAPA, score complaints — a quality owner approves classification and closure

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM REPEAT FINDINGS TO ROOT CAUSE

Quality / CAPA & Complaints

A governed quality copilot that triages complaints, drafts root-cause analysis and CAPA records, and flags MDR reportability — while a quality owner approves every classification, reportability call, and closure.

#1 cited

CAPA (21 CFR 820.100) is consistently the most-cited FDA device 483 clause

[gov/peer-reviewed — FDA]

561

drug-program 483s issued in FY2024 (211.192 cites up ~171% YoY)

[gov/peer-reviewed + sector-press]

$10M–$100M

typical pharma recall cost depending on scope

[industry-research]

The Issue & The Cost of Doing Nothing

THE ISSUE

- Product-complaint volumes are large; CAPA root-cause consistency is a recurring inspection finding.
- On-time CAPA closure rates are a perennial 483/warning-letter theme.
- Complaint handling (820.198) is among the most error-prone QSR areas for device makers.
- FDA's QMSR (effective Feb 2026) raises the bar on quality-record integrity and traceability.

THE COST OF DOING NOTHING

$10M–$100M / recall

Industry: a pharma recall runs $10M–$100M by scope; non-routine device quality events are estimated at $2.5B–$5B/yr industry-wide. CAPA and complaint handling are the perennial top inspection findings.

- Warning letters and consent decrees from repeat root-cause and closure findings.
- Recall and MDR exposure from late or mis-classified complaints.

[industry-research — recall-cost analysis; FDA inspection data]

The design line: the agent drafts root-cause, CAPA, and reportability recommendations; a quality owner approves classification, MDR reportability, and closure.

How We Solve It — A Governed Pipeline

Read complaints and quality events through a scoped gateway, draft root-cause and CAPA and flag reportability — then route every disposition to a quality owner.

1
Ingest complaints/events
QMS + complaint DB via gateway connectors

→

2
Triage & cluster
severity, similar-event clustering, trends

→

3
Draft RCA + CAPA
root-cause draft, CAPA, MDR reportability flag

→

4
HUMAN GATE
quality owner approves classification & closure

→

5
Append-only audit
every decision logged to immutable store

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

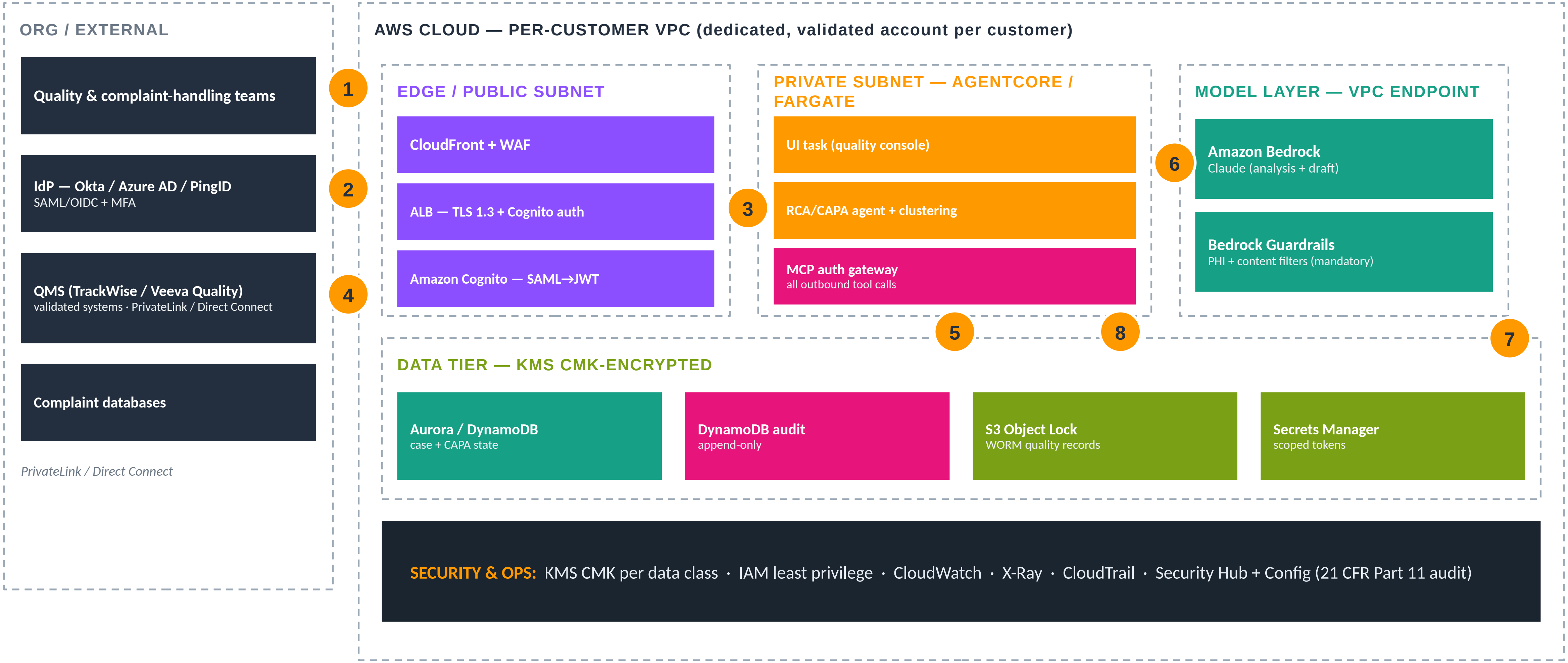
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides the CAPA disposition or reportability

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 user sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to quality console 4 QMS + complaint-DB reads over private connectivity 5 demand scales the agent workers 6 model calls stay in-VPC via Bedrock + Guardrails 7 every classification, RCA, and closure persisted to append-only audit 8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

consistency

structured RCA vs. variable manual root-cause

[design property]

reportability

MDR flag drafted; quality owner decides

[design property]

#1 finding

CAPA is the clause this directly addresses

[gov/peer-reviewed — FDA]

QMSR-ready

audit + traceability posture for Feb 2026

[gov/peer-reviewed]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (analyst / quality-owner roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect TrackWise/Veeva Quality + complaint DB.
1. Enable S3 Object Lock + append-only audit; run smoke + HITL test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway; point connectors at the QMS and complaint database.*

aws-native-reference/05-quality-capa/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Clinical Protocol Design & Feasibility

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 06 of 8 · draft protocol sections grounded in guidance and RWD — clinical leads own the design

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM REWRITES TO RIGHT-FIRST-TIME

Clinical Protocol Design & Feasibility

A governed protocol copilot that drafts sections grounded in current guidance and links feasibility assumptions to real-world data — while clinical and medical leads own the design, reducing the avoidable amendments that delay every trial.

~57%

of protocols incur ≥1 substantial amendment; ~45% avoidable

[industry-research — Tufts]

$535K

median direct cost of a substantial Phase III amendment

[industry-research — Tufts]

~44%

rise in distinct Phase II/III procedures since 2009 (complexity)

[industry-research — Tufts]

The Issue & The Cost of Doing Nothing

THE ISSUE

- First-draft protocols incorporate historical guidance and study data late, driving rework.
- Feasibility assumptions are often not linked to real-world data, so they prove optimistic.
- Phase III protocols with ≥1 substantial amendment have risen toward ~82% in recent benchmarking.
- Each substantial amendment adds direct cost and a 60–80-day cycle delay valued at ~$800K/day.

THE COST OF DOING NOTHING

~$535K / amendment

Modeled: preventing one avoidable Phase III amendment ≈ $535K direct (Tufts) + a ~60–80-day delay valued at ~$800K/day lost sales. ~45% of substantial amendments are avoidable.

- Compounding delay cost from each amendment cycle.
- Enrollment and site disruption when protocols change mid-study.

[modeled — Tufts 2016 amendment cost + Tufts 2024 delay-day]

The design line: the agent drafts sections and surfaces feasibility evidence; clinical and medical leads own the protocol design — nothing is finalized unedited.

How We Solve It — A Governed Pipeline

Retrieve current guidance and historical/RWD evidence through a scoped gateway, draft grounded sections and feasibility — then route the design to clinical leads.

1
Retrieve guidance + data
RIM guidance + historical/RWD via gateway

→

2
Draft sections
objectives, endpoints, eligibility — grounded

→

3
Link feasibility
eligibility vs. RWD cohort feasibility

→

4
HUMAN GATE
clinical / medical leads own the design

→

5
Append-only audit
draft + source lineage logged

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

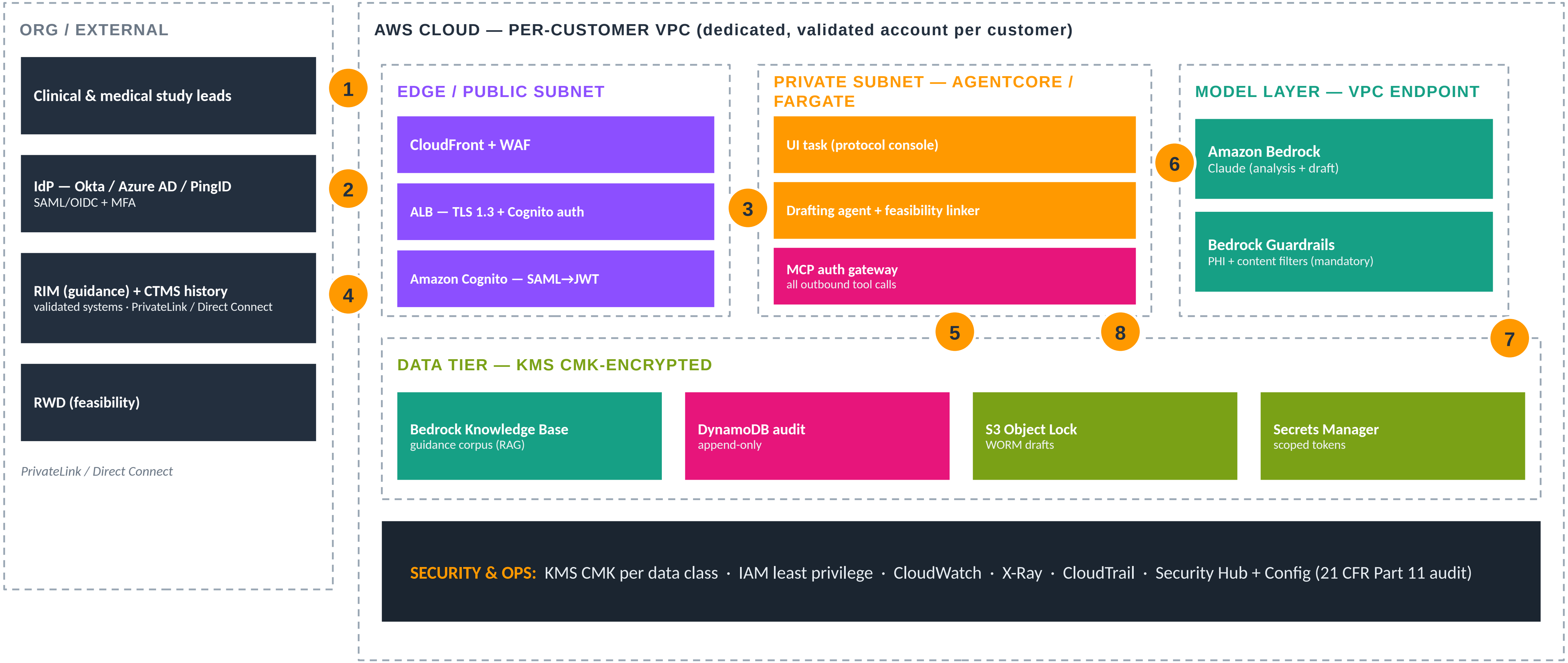
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides the protocol design

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 user sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to protocol console 4 guidance + historical/RWD reads over private connectivity 5 demand scales the agent workers 6 model calls stay in-VPC via Bedrock + Guardrails 7 every draft and source persisted to append-only audit 8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

~45%
of substantial amendments are avoidable — the target

[industry-research — Tufts]

$535K
direct cost avoided per prevented Phase III amendment

[industry-research — Tufts]

grounded
current guidance incorporated at first draft

[design property]

RWD-linked
feasibility tied to real cohort sizing

[design property]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (clinical / medical-lead roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect RIM guidance + CTMS history; connect an RWD source for feasibility.
1. Enable S3 Object Lock + append-only audit; run smoke + HITL test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway; index guidance into a Knowledge Base; connect historical + RWD sources.*

aws-native-reference/06-protocol-design/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Real-World Evidence / HEOR

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 07 of 8 · build cohorts and translate code so analysts analyze — an epidemiologist approves the study

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM WRANGLING TO EVIDENCE

Real-World Evidence / HEOR

A governed RWE/HEOR copilot that defines cohorts, translates between code systems, and assembles auditable data lineage — so analysts spend time on analysis, while an epidemiologist or biostatistician approves the study and its conclusions.

~45%

of analyst time goes to data prep, not analysis (measured)

[sector-press/estimate — Anaconda]

~6 months

to manually build a retrospective RWE database study

[sector-press/estimate]

~$1.3M / yr

non-analytic labor for a 20-person RWE team (modeled)

[modeled]

The Issue & The Cost of Doing Nothing

THE ISSUE

- RWE/HEOR requires cohort definition, confounding control, and structured code translation.
- Analyst time is disproportionately spent on data wrangling rather than evidence generation.
- FDA's RWE Framework hinges on data fitness-for-purpose and auditable lineage — hard to do by hand.
- Follow-on FDA RWD/RWE guidances (2023–24) keep raising the bar on traceability.

THE COST OF DOING NOTHING

~$1.3M / yr / team

Modeled: analyst ~$150K fully loaded × ~45% on wrangling = ~$67K/yr each; a 20-person RWE team ≈ ~$1.3M/yr of non-analytic labor. A single study can take ~6 months to build before analysis.

- Slow evidence generation that delays HEOR dossiers and market-access decisions.
- Lineage gaps that weaken the fitness-for-purpose case to FDA.

[modeled — loaded analyst cost × Anaconda data-prep share]

The design line: the agent builds cohorts, translates code, and documents lineage; an epidemiologist or biostatistician approves the study design and conclusions.

How We Solve It — A Governed Pipeline

Read de-identified RWD through a scoped gateway, define cohorts and translate code with full lineage — then route the study to a qualified human.

1
Read de-identified RWD
claims / registry / RWD via gateway

→

2
Define cohort + translate
phenotype, code-system mapping, lineage

→

3
Draft analysis plan
confounding controls, feasibility counts

→

4
HUMAN GATE
epidemiologist / biostatistician approves

→

5
Append-only audit
data lineage + decisions logged

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

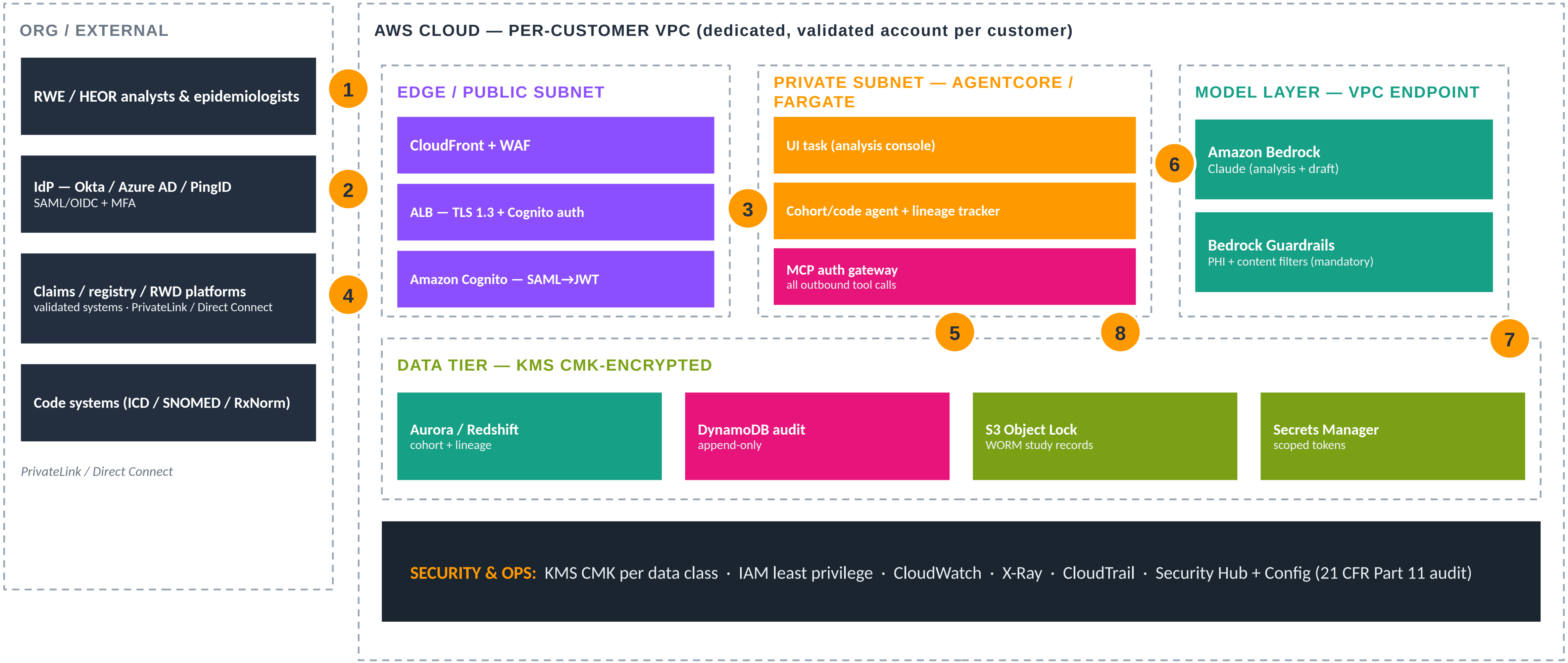
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides the analysis & conclusions

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 analyst sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to analysis console 4 de-identified RWD reads over private connectivity 5 demand scales the agent workers 6 model calls stay in-VPC via Bedrock + Guardrails 7 full data lineage + decisions persisted to append-only audit 8 connectors reachable only through the governed MCP gateway (de-identification enforced)

Proof, Payback & How to Deploy

MEASURED OUTCOMES

~45% → 90%

analyst time shifted from prep toward analysis

[design target vs. Anaconda baseline]

lineage

auditable data provenance for FDA fitness-for-purpose

[gov/peer-reviewed — FDA RWE]

code xlat

ICD/SNOMED/RxNorm mapping with provenance

[design property]

hours → min

vendor proxy: AstraZeneca analyst acceleration

[vendor — AWS]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (analyst / epidemiologist roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect de-identified claims/registry/RWD; enforce de-identification at the gateway.
1. Enable S3 Object Lock + append-only audit; run smoke + HITL test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway; point connectors at de-identified RWD; wire code-system references.*

aws-native-reference/07-rwe-heor/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Medical Affairs / MSL Copilot

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 08 of 8 · draft on-label, evidence-grounded HCP responses — MLR review approves before anything ships

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM WEEKS IN MLR TO DAYS

Medical Affairs / MSL Copilot

A governed Medical Affairs copilot that drafts on-label, evidence-grounded responses for HCP interactions with off-label guardrails enforced technically — while MLR review approves everything before it reaches a healthcare professional.

weeks → months

MLR review is the single biggest content-release bottleneck

[sector-press/estimate]

50–70%

potential reduction in time-to-deliver for medical-legal reviews

[industry-research — McKinsey]

$3B / $2.3B

record off-label promotion settlements (GSK / Pfizer)

[gov/peer-reviewed — DOJ]

The Issue & The Cost of Doing Nothing

THE ISSUE

- Field medical teams need rapid, on-label, evidence-grounded responses for HCP interactions.
- Off-label guardrails must be technical, not procedural — a policy SOP is not a control.
- MLR cycles routinely stretch from weeks into months, causing missed launch windows.
- Off-label promotion is among the highest-dollar compliance risks in pharma.

THE COST OF DOING NOTHING

Billions in FCA risk

DOJ recovered $6.8B in total FY2025 False Claims Act recoveries (healthcare a leading category). Record off-label settlements: GSK $3B, Pfizer $2.3B, J&J $2.2B, AstraZeneca $520M.

- Off-label promotion liability and corporate-integrity-agreement exposure.
- Missed launch windows when MLR is the bottleneck.

[gov/peer-reviewed — DOJ; industry-research — McKinsey]

The design line: the agent drafts on-label, grounded responses within Guardrails; MLR review approves before anything reaches an HCP — off-label is blocked technically.

How We Solve It — A Governed Pipeline

Retrieve approved label and evidence through a scoped gateway, draft on-label responses within Guardrails — then route every response through MLR before delivery.

1
Retrieve label + evidence
approved label/DMS via Knowledge Base

→

2
Draft on-label response
grounded; off-label blocked by Guardrails

→

3
Annotate references
claims linked to approved sources

→

4
HUMAN GATE
MLR review approves before HCP delivery

→

5
Append-only audit
every response + approval logged

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

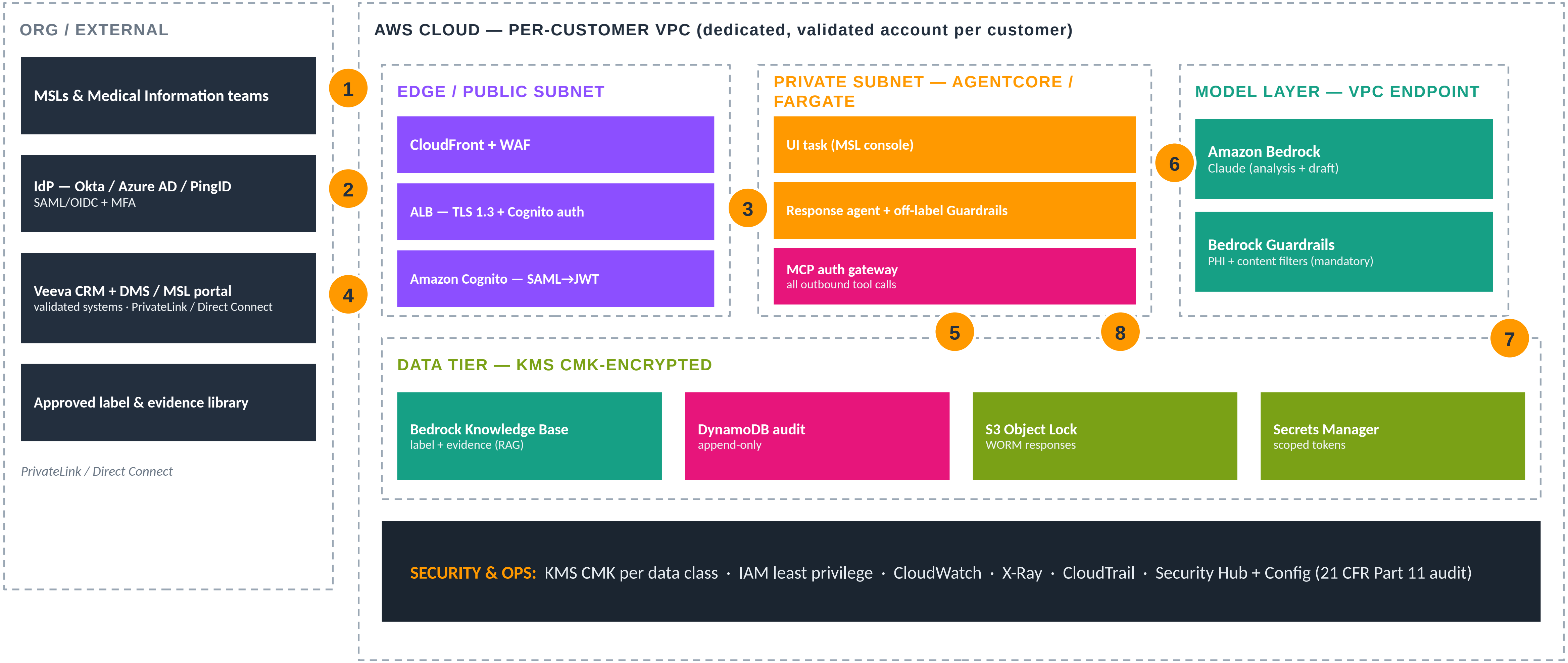
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides what reaches an HCP

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 MSL sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to MSL console 4 CRM/DMS + label reads over private connectivity 5 demand scales the agent workers 6 model calls stay in-VPC via Bedrock + Guardrails (off-label filters mandatory) 7 every response and MLR approval persisted to append-only audit 8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

50–70%

potential MLR time-to-deliver reduction

[industry-research — McKinsey]

20–30%

medical-writing cost savings (rising as it matures)

[industry-research — McKinsey]

technical

off-label guardrail enforced, not procedural

[design property]

~$3–5B/yr

potential Medical Affairs efficiency industry-wide

[industry-research — McKinsey]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (MSL / MLR-reviewer roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect Veeva CRM/DMS; index approved label + evidence; set off-label Guardrails.
1. Enable S3 Object Lock + append-only audit; run smoke + HITL (MLR) test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway; connect Veeva CRM/DMS, index the approved label, and set off-label Guardrails.*

aws-native-reference/08-medical-affairs-msl/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

Manufacturing Batch-Review

A Governed Agentic AI Reference Architecture for Life Sciences

Agent 09 of 8 · review electronic batch records by exception — QA owns every release/reject

HCLS AI Agent Suite

HCLS AI Agent Suite · Built on AWS · June 2026

FROM 48-HOUR REVIEWS TO REVIEW BY EXCEPTION

Manufacturing Batch-Review

A governed batch-review copilot that reads the electronic batch record and process data, flags deviations and out-of-spec results by exception, and drafts the disposition — while a QA reviewer makes and signs every release/reject decision.

62%

of US drug shortages trace to manufacturing/quality problems — the #1 root cause

[gov/peer-reviewed — FDA]

~48 hrs

average review per batch report today (up to ~500 hrs for complex paper-based)

[sector-press/estimate]

~$14K

average cost per deviation investigation (mostly senior labor)

[sector-press/estimate]

The Issue & The Cost of Doing Nothing

THE ISSUE

- Batch-record review and OOS/deviation investigation are slow, manual, and senior-labor-heavy.
- 21 CFR 211.192 (production-record review / discrepancy investigation) is among the most-cited FDA warning-letter findings.
- Right-first-time for complex biologics often sits ~80%; every non-RFT batch triggers rework and release delay.
- A single biologics batch failure can cost tens of millions; raw materials alone often exceed $1–2M.

THE COST OF DOING NOTHING

~$420K / yr

Modeled: 200 batches/yr × ~15% deviating (85% RFT) ≈ 30 investigations × ~$14K labor ≈ ~$420K/yr — before any scrapped batch ($1–2M+ each) or delayed-release carrying cost.

- Release delays and drug-shortage risk from review backlogs.
- Data-integrity / 211.192 findings from inconsistent record review.

[modeled — deviation-investigation cost × batch volume]

The design line: the agent reviews records and flags exceptions; a QA reviewer makes and signs the final release/reject decision — the agent never releases a batch.

How We Solve It — A Governed Pipeline

Read the electronic batch record + MES/LIMS data through a scoped gateway, check by exception and draft the disposition — then stop at a QA gate before release.

1
Read EBR + MES/LIMS
batch record + process/QC data via gateway

→

2
Check by exception
limits, OOS, missing steps, e-sig completeness

→

3
Draft disposition
exception report + recommended release/hold

→

4
HUMAN GATE (QA)
QA reviewer approves release / reject

→

5
Append-only audit
every check + decision logged

Every action audited

node, timestamp, actor, data sources, model + prompt version — append-only and inspection-ready (21 CFR Part 11).

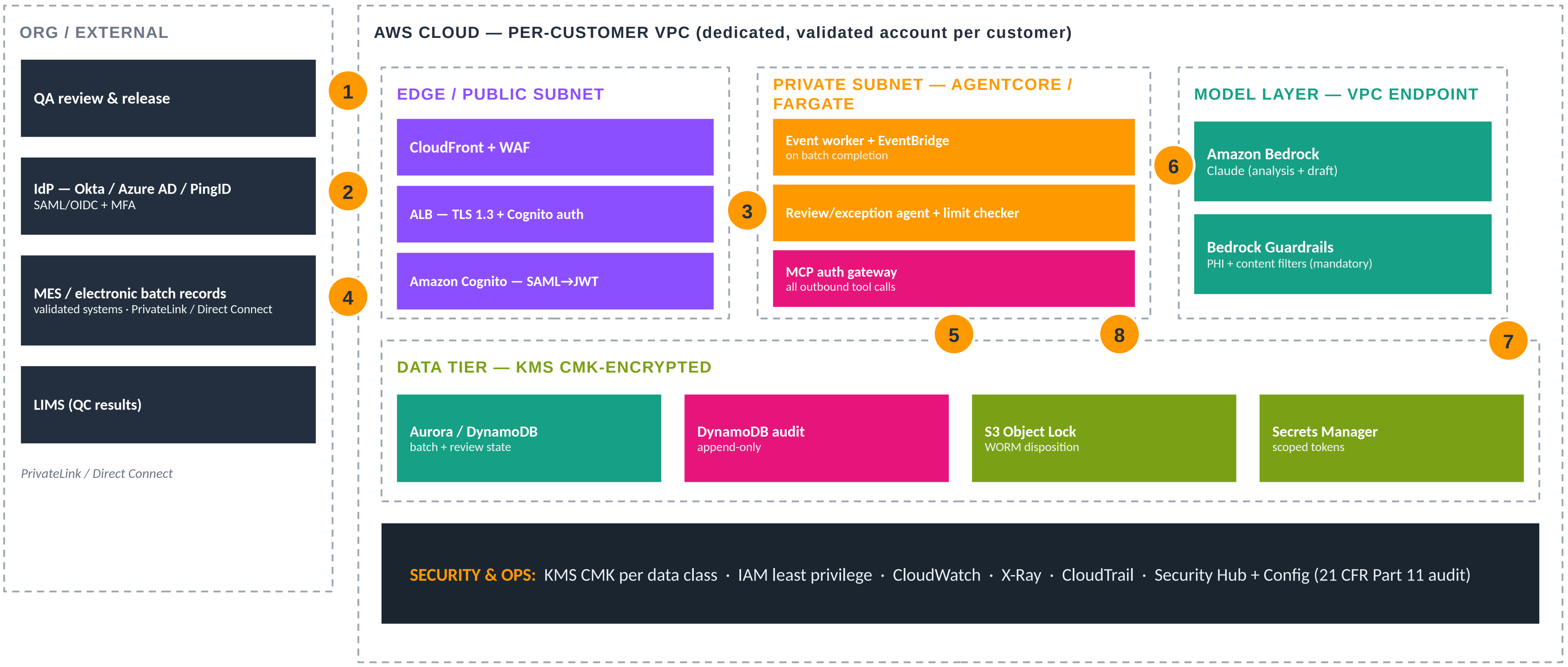
Grounded & explainable

every regulated claim traces to the source corpus; Bedrock Guardrails mask PHI before any model call and bound the output.

AI never decides batch release

the consequential action is a human-only step, enforced in the orchestration framework — not a policy SOP.

AWS Architecture & Traffic Flow



1 QA sign-in 2 SAML federation (MFA at IdP; Cognito issues JWT) 3 authenticated session to review console 4 MES/EBR + LIMS reads over private connectivity 5 EventBridge triggers review on batch completion 6 model calls stay in-VPC via Bedrock + Guardrails 7 every flag, exception, and release decision persisted to append-only audit (21 CFR Part 11) 8 connectors reachable only through the governed MCP gateway

Proof, Payback & How to Deploy

MEASURED OUTCOMES

~80%

batch-release time cut with review by exception

[sector-press/estimate]

>50%

deviation reduction at a benchmarked biopharma site

[industry-research — McKinsey]

#2 cited

211.192 record-review is a top FDA warning-letter finding

[gov/peer-reviewed]

36 tests

passing with no API key (built to flagship depth)

[built]

WHAT IT TAKES TO DEPLOY

1. Provision KMS CMK + per-customer validated VPC / network.
1. Stand up Cognito SAML→JWT federation (operator / QA-reviewer roles).
1. Front with CloudFront + WAF, ALB TLS 1.3.
1. Deploy the agent + grant tools via the MCP gateway (deny-by-default).
1. Connect MES / electronic batch records + LIMS; wire EventBridge on batch completion.
1. Enable S3 Object Lock + append-only audit; run smoke + QA-gate test.

Deploy: *CloudFormation quick-deploy provisions the isolated environment + dual MCP gateway + connector Lambdas (mes/lims); connect MES/EBR + LIMS. AWS-native Strands + Step Functions rebuild included.*

aws-native-reference/09-manufacturing-batch-review/DEPLOY.md · docs/DEPLOY-QUICKSTART.md

The takeaway: the agent isn't the product — the governed platform that makes it 21 CFR Part 11 / GxP-defensible and deployable on AWS is.

HCLS AI AGENT SUITE

Infrastructure & Adoption Review

A CIO / CISO / Director of Architecture perspective

THE VERDICT, UP FRONT Adopt as a governed accelerator to compress an SI-led build — not as a turnkey, validated product.

8 governed agents · AWS-native · 21 CFR Part 11 / GxP · GVP/E2B · HIPAA · FDA AI guidance (Jan 2025) · NIST AI RMF

BOTTOM LINE UP FRONT

Adopt it as a governed accelerator — not a finished product

What you are buying

A governance spine in code + 452 tests, AWS deployment runbooks, and a reference architecture (dual MCP gateway, in-VPC Bedrock, HITL, audit). It hands an SI a compliant, auditable starting point across 8 life-sciences workflows.

What you still build

Live Veeva / Argus / Medidata / QMS connectors, the reviewer UI, IdP federation, computer-system validation (CSV/CSA), and a penetration test. This is an engagement, not an install.

Why that is the right buy

It moves the hard, slow, risky part — governed access, HITL, audit, PHI masking, grounding — off your critical path. You compress months of SI build while keeping GxP / 21 CFR Part 11 accountability where it belongs: with you.

Recommendation: Approve a funded Phase-1 pilot on the lowest-decision-risk agents. Prove the gateway, audit, PHI masking, and HITL gate in production, then expand. Do not present this to the board as a product you can turn on next week.

The maturity ladder — positioned honestly

1 **Documented**
Architecture, workflow & compliance design written and reviewed

2 **Demonstrated**
Runs end-to-end in demo mode — deterministic fixtures, no API key (452 tests green)

3 **Deployable**
CloudFormation + Terraform + container contract pass CI; needs your AWS account + Bedrock

4 **Production-ready**
CSV/CSA validation, IdP, live connectors, pen test — the engagement

BRIGHT LINE — the engagement starts here

Real today

- Governance spine in code + 452 passing tests (gateway intersection, HITL, PHI masking, grounding, red-team) — no API key
- Empty-account-to-running CloudFormation quick-deploy: connector Lambdas + dual MCP gateway + native/container agent; Terraform parity
- Live reference path (Agent 02): real Bedrock + real HTTP connector, end-to-end; Strands + Step Functions waitForTaskToken HITL

A starting point, not finished

- Live connectors run on fixtures; production validation against Veeva / Argus / Medidata / QMS is yours
- AgentCore managed-gateway registration uses customer-supplied custom-resource placeholders; reviewer UI is an SI build
- No computer-system validation (CSV/CSA) package of its own, no SOC 2 / 3rd-party cert, no pen-tested production surface yet

Why a CISO or QA / regulatory lead can say yes

Governance-first: the controls are enforced in the gateway, outside the model — a prompt cannot turn them off.

Deny-by-default gateway

permitted(tool) = agent-grant ∩ user-entitlement. An agent can never exceed the human it acts for. Denies on a missing subject.

Framework-enforced HITL

Consequential actions block as PENDING_APPROVAL until a named, correctly-roled reviewer binds identity (21 CFR Part 11 e-signature). Fails closed on timeout.

Tamper-evident audit

Append-only DynamoDB + S3 Object Lock WORM. Every ALLOW / DENY / PENDING / ERROR logged with lineage — Part 11 / ALCOA+ recordkeeping.

PHI / PII masking

Patient identifiers replaced with stable pseudonyms before any prompt or audit record. Stateless, runs before every gateway call.

Grounding verification

Every figure / entity in a regulated artifact must trace to the source corpus; grounding fails fast rather than asserting a hallucinated claim.

Fairness / diversity screen

Representativeness flags on proposed cohorts (FDA Diversity Action Plan posture); outcomes routed to human review — no automated adverse action.

Mapped to the life-sciences regulatory stack: 21 CFR Part 11 · GxP / ALCOA+ · GVP / ICH E2B(R3) · ICH E6(R3) GCP · HIPAA / de-identification · FDA AI guidance (Jan 2025) · EMA AI reflection paper · NIST AI RMF. The bright line — causality, reportability, what is submitted, CAPA disposition, patient eligibility, what reaches an HCP — is never decided by the agent.

Where it falls short — open risks today

Drawn directly from the deployment reference's own “gaps / what you must add” callouts. None are hidden; all are scoped.

STUB

Live connectors are fixtures

Veeva / Argus / Medidata / QMS run on deterministic fixtures; live validation against your systems is the engagement.

GAP

No CSV/CSA package yet

Computer-system validation (IQ/OQ/PQ) is the regulated production gate; the suite ships the design, not the executed package.

BUILD

Reviewer UI is your build

The HITL gate + queue ship; the screen a safety physician / writer / MLR reviewer uses to approve is a customer/SI build.

PART

AgentCore = placeholders

Managed Gateway & Runtime register via customer-supplied custom-resource Lambdas; portable gateway mode is the fallback.

PART

Observability to author

CloudWatch alarms / dashboards are per-environment; runbooks assume alarms and CloudTrail config you finalize.

PART

KB ingestion partial

Bedrock Knowledge Base ingestion IaC is a stub to build out per corpus (guidance, label, SOPs).

RISK

No cert · cost · accuracy

No SOC 2 / 3rd-party cert. Bedrock model cost & clinical accuracy must be validated against your data.

RISK

Change control is process

Prompt / model promotion change-control is framework-supported but operated by you under your quality system.

The questions to answer before you adopt

Data residency & GxP terms

Which Region? Does it meet data-localization and GxP data-integrity requirements? Are the controls Part 11-aligned in the vendor agreement?

DPA / BAA in place

Data-processing / business-associate agreement executed; vendor TPRM questionnaire signed off before any live patient or safety record is touched.

IdP federation

Can your IdP (Okta / Entra / Ping) express the reviewer roles (writer / safety physician / CRA / MLR)? Cognito ↔ IdP claim mapping is the most common readiness gap.

CSV / validation plan

Who owns the computer-system validation (IQ/OQ/PQ) and the validation lifecycle? Plan it before any GxP go-live.

Penetration test

Independent pen test of the deployed surface is a production-readiness gate — budget and schedule it before go-live.

Total cost of ownership

Bedrock inference + infra + SI delivery. Model the run-rate, not just the build; set Budgets + Cost Anomaly Detection on Bedrock.

Support & maintenance model

Who owns prompt/model change control, patching, and the managed-service SLA after the SI hands off?

Model-drift monitoring

Who watches grounding-failure rate, Guardrail block rate, and eval regression once it is live, and on what cadence?

Who owns what — platform, identity, security, data

Developer / SI — deploys & maintains · Customer — sponsor IT / security / QA / regulatory · User — staff operating the agents

Responsibility domain	User	Customer (sponsor)	Developer / SI
Platform & infrastructure — accounts, network, KMS, edge	—	C/I	R/A
Identity & access — IdP, Cognito federation, IAM roles	—	R/A	C/I
Security & compliance — GxP / Part 11 program, audits, pen test	C/I	R/A	C/I
Connectors & data — Veeva/Argus/Medidata integration, data quality, KB content	—	R/A	R/A

Where two parties show R/A, the control only holds if both act — e.g. the SI builds the connector; the sponsor provides credentials, approves scopes, and validates against the live, validated system.

Platform & infra

SI designs & deploys the VPC, KMS, and data plane per the templates; your cloud team approves network & key policy and owns the CMK. Edge hardening is finalized for production.

Identity & access

The IdP is yours — reviewer-role definitions (writer / safety physician / CRA / MLR) are sponsor policy. The SI implements the Cognito claim mapping; you own its accuracy.

Connectors & data

No connector points at a live system without your scope approval and a signed pilot SOW. Stale or wrong KB content is a sponsor risk; the SI implements change control.

Who owns what — model, validation, human-in-the-loop

- Developer / SI — deploys & maintains
- Customer — sponsor IT / security / QA / regulatory
- User — staff operating the agents

Responsibility domain	User	Customer (sponsor)	Developer / SI
Model & guardrails — Bedrock access, Guardrails tuning, eval & change-control	—	R/A	R/A
Validation — CSV/CSA (IQ/OQ/PQ) testing & sign-off	—	R/A	R/A
HITL operations — approving consequential actions, reviewer roster	R/A	R/A	C/I
Reviewer UI / HITL handoff surface — build & operate	—	C/I	R/A

The human gate is the bright line. The SI builds it; the sponsor staffs it with qualified, correctly-roled reviewers (e.g. a safety physician for causality) — this cannot be delegated to the SI.

Model & guardrails

The SI recommends & implements per-agent Guardrail policy, prompt pinning, and the eval harness; your quality, safety & regulatory leadership approve it, and a named reviewer signs off promotions under change control.

Validation (CSV/CSA)

Computer-system validation is a production-readiness gate, not optional. The SI supports IQ/OQ/PQ during the engagement; you own the validation lifecycle and final sign-off in your quality system.

HITL operations

Consequential actions are approved by your named, correctly-roled reviewers (regulatory writer / safety physician / CRA / MLR). The SI runs the technical gate; you define what counts as "consequential."

Who owns what — operations, change, training

- Developer / SI — deploys & maintains
- Customer — sponsor IT / security / QA / regulatory
- User — staff operating the agents

Responsibility domain	User	Customer (sponsor)	Developer / SI
Support & monitoring — alarms, dashboards, run-rate ops	—	C/I	R/A
Incident & deviation response — detection, containment, reporting	—	R/A	R/A
Change management — prompt / model upgrades, production promotion	C/I	R/A	R/A
Training & SOPs — staff enablement, the bright line, acceptable use	R/A	R/A	C/I

Operationally: the SI builds and runs the technical controls; the sponsor makes every regulated determination — deviation/CAPA, production sign-off, and SOP enforcement under its quality system.

Support & monitoring

Alarm thresholds, pager routing, and retention windows are sponsor-owned; the SI builds the dashboards and runs managed-service operations against your SLAs.

Incident & deviation

The SI executes the runbook, produces audit evidence, and notifies you fast; you make the regulated determination — deviation, CAPA, and any reportability to authorities — under your quality system.

Change & training

No prompt, model, or tool-grant change reaches production without your sign-off under change control. You own the SOPs and train staff on what the agent does and does not decide; the SI supplies capability docs.

What is still to be done

Live connectors

Validated adapters for live Veeva (RIM/Vault/CRM), Argus/Veeva Safety, Medidata, and QMS (TrackWise).

CSV / CSA package

Executed IQ/OQ/PQ validation and the traceability matrix under the sponsor's quality system.

KB ingestion pipeline

Bedrock Knowledge Base ingestion IaC built out from the stub per corpus (guidance, label, SOPs), grounding wired in.

Edge + observability IaC

CloudFront / WAF hardening and CloudWatch alarms + dashboards authored per environment.

Cedar / OPA policy export

Export the gateway authorization model to a standard policy engine for external review & reuse.

Penetration test

Independent pen test of the deployed surface — a production-readiness gate.

Reviewer UI

The HITL approve/reject surface that authenticates the reviewer and binds the e-signature into the record.

Production-readiness review

Full security & quality review, IdP integration tested, and sponsor acceptance sign-off.

Land low-risk, prove the controls, then expand

1 Pilot — land here

Lowest decision-risk, highest visibility

AGENTS

01 Regulatory Writing · 02 Pharmacovigilance (live path) · 03 Trial Ops/TMF · 08 Medical Affairs

GOAL / PHASE GATE

Prove the gateway, PHI masking, audit trail, and HITL gate in production. Measure cycle-time and reviewer throughput.

2 Expand — on evidence

Higher-value, higher-governance

AGENTS

05 Quality / CAPA · 06 Protocol Design

GOAL / PHASE GATE

Add agents that touch reportability and study design — only after eval, grounding, and audit are proven in production.

3 Operate — at scale

Managed service & continuous assurance

AGENTS

Full suite under change control · de-identified-RWD agents 04 / 07 · model-drift monitoring · annual pen test

GOAL / PHASE GATE

Steady-state operations with named reviewers, alarms, and a production-readiness review behind each promotion.

Phase gates: Each phase advances only when the prior clears its gate — clean audit trail, HITL gate exercised on real approvals, measured cycle-time, and a security/quality sign-off. Best demo entry point: Agent 02 (Pharmacovigilance) — the only agent with a live Bedrock + real-connector path you can run end-to-end. Safest document start: Agent 01.

DECISION SUMMARY

Go / no-go criteria

GO if you can commit to…

- A funded SI-led engagement, not a product purchase
- Owning the GxP / Part 11 quality program, IdP, and reviewer roster
- A pilot scoped to Agents 01 / 02 / 03 / 08 with phase gates
- Budget for CSV/CSA validation + a pen test before go-live
- Validating Bedrock cost & clinical accuracy against your own data

NO-GO / wait if…

- You need a certified, turnkey product to switch on now
- There is no budget or partner for SI delivery & maintenance
- Your IdP cannot express the reviewer roles and there is no plan to fix it
- You expect the vendor to assume GxP / Part 11 accountability
- You cannot staff qualified HITL reviewers (e.g. a safety physician)

Recommendation: Approve a funded Phase-1 pilot on Agents 01 / 02 / 03 / 08. It compresses an SI-led build with a governance spine your CISO and QA/regulatory leadership can stand behind — while you keep GxP / Part 11 accountability and prove the controls in production before expanding.